

MITM: ARP Spoofing & DNS Poisoning

The LAN assumption

On a switched Ethernet LAN, traffic between hosts goes point-to-point. But switching trusts **ARP and L2 tables**, which we can abuse to insert ourselves on-path.

ARP spoofing (the classic)

Host A wants to reach gateway → sends ARP "who has IP X?"

Attacker replies for BOTH A and gateway: "I have that IP" (MAC = attacker)

All A→gateway traffic now flows through the attacker

```
# bettercap (modern), authorized lab:
sudo bettercap -iface eth0 -eval '
  set arp.spoof.targets 10.0.0.30; arp.spoof on; net.sniff on'
```

DNS poisoning / spoofing

Attacker-in-the-middle: rewrite DNS answers → victim resolves evil.com to attacker IP

Or ARP-spoof the DNS server itself

Victim visits "bank.com" but reaches the attacker's page (if TLS isn't total, or via typosite with stolen certs)

For the lab: bettercap/ettercap dns_spoof module

Sniffing the reward

```
# capture what flows through you
tcpdump -i eth0 -w mitm.pcap
```

```
tshark -r mitm.pcap -Y 'http.request.method==GET || http.request'
# observe plaintext usernames/passwords -> then REPORT how TLS fixes it
```

The defense table

Defense	Kills
Dynamic ARP Inspection (DAI, on the switch)	ARP spoofing at port
802.1X (per-port auth)	Unauthenticated devices cannot MITM
TLS everywhere (HSTS, cert pinning)	Even on-path attacker reads nothing
BPDU guard + DHCP snooping	Switch-side hygiene
Static ARP / DHCP reservations (small nets)	Practical for labs

MITM labs teach the "why TLS" question better than any slide: sniff a plaintext HTTP login between your own VMs and watch credential bytes flow past you.

[← Module start](#)[Layer-2 & Switch Attacks →](#)